

Vendor Risk Assessment Document

Document Title: Vendor Risk Assessment – PaySecure

Prepared For: GreenLeaf E-Commerce Management Team

Prepared By: Cameron Naidoo, GRC Analyst

Date: 24 June 2026

Version: 1.0

Classification: Confidential

1. Executive Summary

GreenLeaf E-Commerce utilizes **PaySecure** as its primary payment processor for customer credit card transactions. This assessment evaluated PaySecure's security posture against GreenLeaf's compliance requirements (including PCI-DSS and data protection best practices).

Overall Risk Rating: HIGH

PaySecure has been unable to provide current independent audit reports (ISO 27001 or up-to-date SOC 2 Type II) and lacks a history of completing formal security questionnaires. This indicates an immature security program that poses a significant risk of data breach, regulatory fines, and reputational damage to GreenLeaf. Immediate risk mitigation is required, with a recommended long-term strategy to replace this vendor.

2. Vendor Profile

Vendor Name	PaySecure
Business Function	Third-party payment processing (credit/debit card transactions)
Criticality to Green-Leaf	CRITICAL – GreenLeaf cannot process customer orders without this service.
Data Access	PaySecure has access to customer names, billing addresses, and partial credit card numbers.

3. Assessment Scope & Methodology

The purpose of this assessment was to verify that PaySecure maintains adequate security controls to protect GreenLeaf's customer payment data.

The assessment was conducted by reviewing the following requested evidence:

1. ISO 27001 Certification.
2. SOC 2 Type II Audit Report.
3. Vendor Security Questionnaire (Standard industry format).

4. Risk Findings & Gap Analysis

The following control gaps were identified during the review of PaySecure's evidence:

Finding ID	Gap Description	Risk Impact
V-001	No ISO 27001 Certification. PaySecure stated they are "in the process" of implementing ISO 27001 but are at least 12 months away from certification.	Without this, GreenLeaf has no independent validation that PaySecure has a properly governed Information Security Management System (ISMS). The vendor may have undocumented or ineffective security processes.
V-002	Outdated SOC 2 Type II Report. The only report provided is 18 months old. A new audit is reportedly underway but will not be available for 4 months.	A SOC 2 report is only valid for the period it covers. An 18-month-old report does not provide assurance about their current operational environment. They have had a full year without independent oversight.
V-003	No Security Questionnaire History. PaySecure confirmed they have never completed a security questionnaire for a client.	This is a major red flag. It indicates that PaySecure is not used to dealing with enterprise-level compliance requirements and likely lacks mature security practices (e.g., patching schedules, access reviews, incident response testing).

5. Risk Scoring

Based on the findings above, PaySecure has been rated as follows:

Risk Dimension	Score	Rationale
Likelihood of a Breach	High (4/5)	The lack of current audits and security questionnaires suggests a reactive, rather than proactive, security culture.
Impact if Breach Occurs	Catastrophic (5/5)	A breach would expose customer financial data, leading to immediate PCI-DSS fines, legal lawsuits, and severe reputational loss.
Overall Residual Risk	HIGH (20/25)	Immediate action is required.

6. Recommended Risk Treatment Strategy

Given the High-Risk rating, a **dual-phase strategy** is recommended:

Phase 1: Immediate Mitigation (Next 30 Days)

Do not terminate PaySecure immediately, but protect GreenLeaf legally and technically.

1. **Legal Addendum:** Demand PaySecure sign a contract addendum holding them fully liable for any breach-related costs, fines, and customer remediation.
2. **Questionnaire Completion:** Set a strict 14-day deadline for PaySecure to complete the standard security questionnaire. If they refuse, escalate to termination.

3. **Monitoring:** Require PaySecure to provide monthly "Security Status" updates until their SOC 2 is current.

Phase 2: Long-Term Avoidance (Next 90 Days)

Permanently eliminate the risk by switching to a secure vendor.

1. **Vendor Search:** Immediately begin evaluating alternative payment processors (e.g., Stripe, Adyen, PayPal) that already hold current ISO 27001 and SOC 2 reports.
2. **Migration Plan:** Develop a 90-day migration plan to transition from PaySecure to the new vendor.
3. **Sunset PaySecure:** Terminate the contract with PaySecure upon successful migration.

7. Conclusion

PaySecure currently presents an unacceptable level of risk to GreenLeaf E-Commerce. While they provide a critical business function, their lack of current security audits and mature compliance processes makes them a liability.

GreenLeaf must **immediately secure contractual protections** while **actively seeking a replacement vendor** to avoid catastrophic exposure to a payment data breach.

8. Document Sign-off

Role	Name	Approval	Date
Assessed By	Cameron Naidoo	Approved	24/06/2026
CEO / Risk Owner	Joseph John	[Pending]	24/06/2026

